

Tasks:

- 1. Open Burp Suite.**
- 2. Visit a practice website or your own application.**
- 3. Capture the following requests:**
 - **Homepage Request**
 - **Login Page Request**
 - **Login Request**
 - **Logout Request**
- 4. Identify:**
 - **Request Method**
 - **Response Code**
 - **Cookies**
 - **Session ID**
 - **Parameters**
- 5. Compare the following:**
 - **Before Login**
 - **After Login**
- 6. Find answers to:**
 - **What changes after login?**
 - **Which cookie is responsible for maintaining the session?**
 - **What happens when you logout?**
 - **Does the session cookie change after login?**
- 7. Send Login Request to Repeater and analyze:**
 - **Headers**
 - **Cookies**
 - **Parameters**
 - **Response**

8. Create a Login Flow Diagram:

Browser → Login Request → Server → Session Creation → Logged In User

Assignment:

Prepare a report containing:

- 1. What is Authentication?**
- 2. What is Authorization?**
- 3. What is a Session?**
- 4. What is a Cookie?**
- 5. Difference between Authentication and Authorization.**
- 6. Difference between Session Cookies and Persistent Cookies.**
- 7. Screenshots of:**
 - Login Request**
 - Login Response**
 - Session Cookie**
 - Logout Request**

Analyze the login flow of:

- Gmail**
- Facebook**
- Instagram**
- Amazon**

Observe:

- Login page**
- Password page**
- Verification page**
- Security features used**

Aim

To analyze the authentication mechanism, session management, cookies, login requests, logout requests, and authorization process of a web application using Burp Suite.

Objective

1. Capture HTTP requests and responses.
2. Analyze login and logout functionality.
3. Identify session cookies.
4. Understand authentication and authorization mechanisms.
5. Compare user state before and after login.
6. Use Burp Repeater to inspect requests.
7. Study login flows of popular websites.
8. Understand session management techniques.

Software Required

- Burp Suite Community Edition
- Google Chrome / Burp Browser
- Internet Connection
- Practice Website

Examples:

- PortSwigger Web Security Academy
- Amazon
- Facebook
- Instagram
- Gmail

PART A – BURP SUITE CONFIGURATION

Step 1: Open Burp Suite

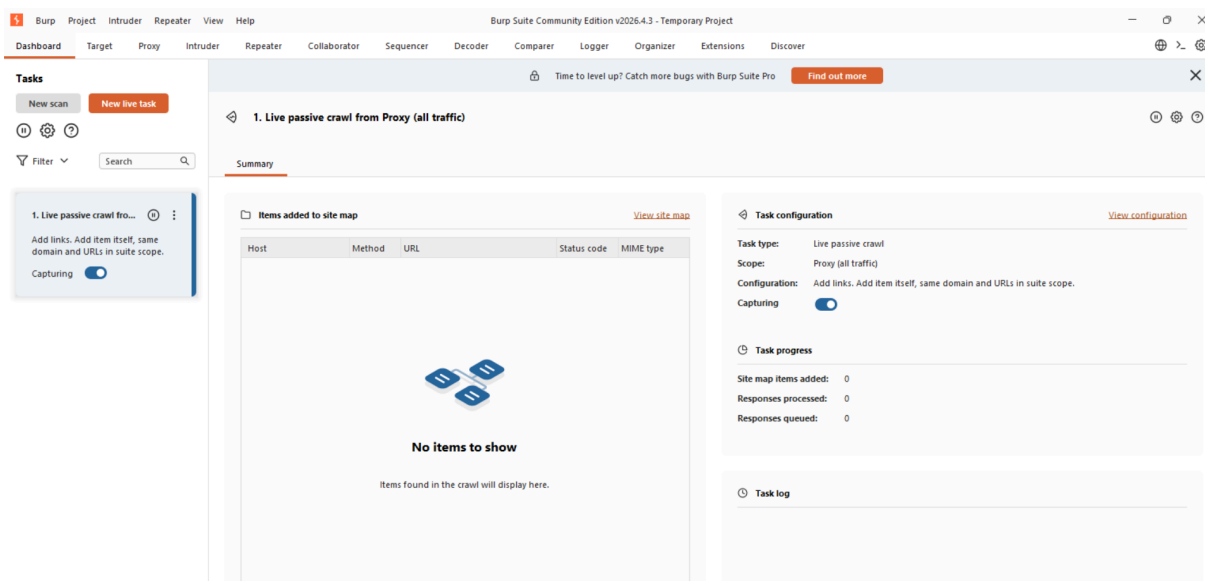
Launch Burp Suite.

You will see:

- Dashboard
- Proxy
- Intruder
- Repeater
- Decoder
- Comparer

Screenshot :

Burp Suite Home Screen



Step 2: Open Burp Browser

Navigate:

Proxy → Intercept → Open Browser

A Chromium browser will open with Burp proxy preconfigured.

PART B – HOMEPAGE REQUEST ANALYSIS

Step 3: Visit Website

Example: Portswigger labs

Homepage loads.

Step 4: Locate Homepage Request

Navigate:

Proxy → HTTP History

Look for:

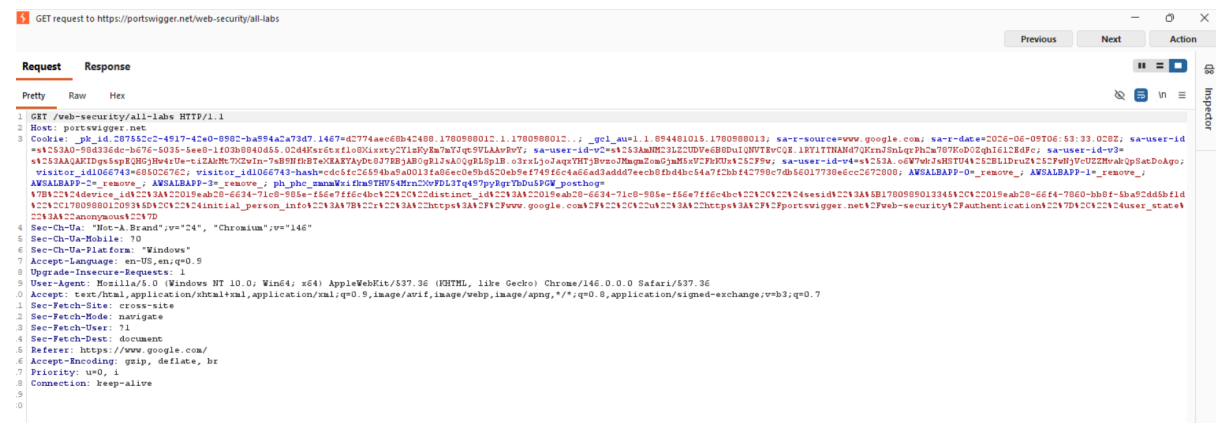
GET /

or

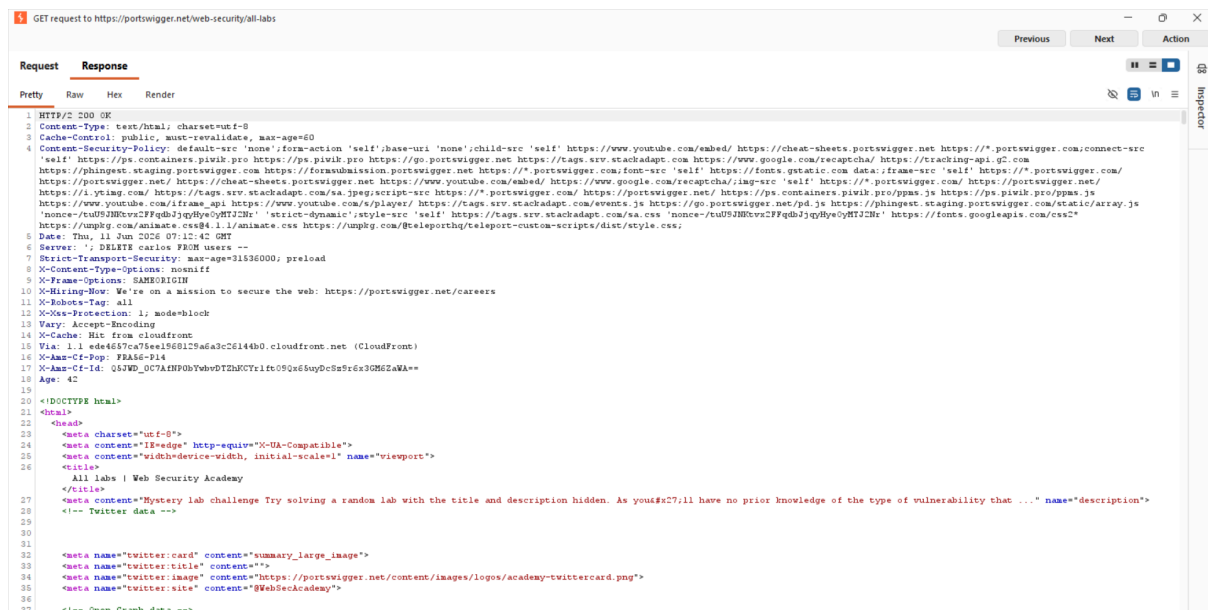
GET /index

Screenshot :

Homepage Request



Screenshot : Homepage Response



Homepage Analysis

Request Method

GET

Purpose

Used to retrieve webpage content from server.

Response Code

200 OK

Meaning

Request processed successfully.

Cookies

Visitor id:1066743

Parameters

Usually none.

Name	Value	
_pk_id.287552c2-4917-42e...	d2774aec68b42488.17809...	>
_gcl_au	1.1.894481015.1780988013	>
sa-r-source	www.google.com	>
sa-r-date	2026-06-09T06:53:33.028Z	>
sa-user-id	s%3A0-98d336dc-b676-50...	>
sa-user-id-v2	s%3AmNM23LZ2UDVe6B8...	>
sa-user-id-v3	s%3AAQAKIDgs5spEQHGj...	>
sa-user-id-v4	s%3A.o6W7wkJsHSTU4%2...	>
visitor_id1066743	685026762	>
visitor_id1066743-hash	cdc5fc26594ba9a0013fa86...	>
AWSALBAPP-0	_remove_	>
AWSALBAPP-1	_remove_	>
AWSALBAPP-2	_remove_	>
AWSALBAPP-3	_remove_	>
ph_phc_zmnmWxifkm9TH...	["\$device_id": "019eab28-6...	>

PART C – LOGIN PAGE REQUEST ANALYSIS

Step 5: Open Login Page

Click:

Login

Sign In

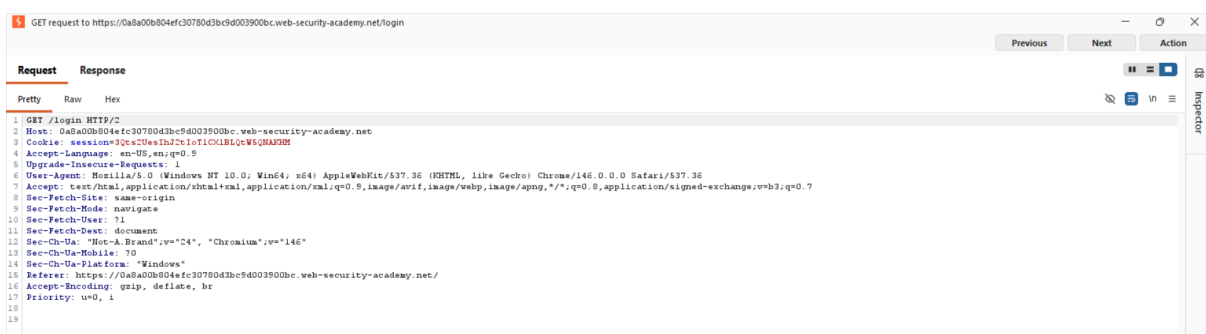
Burp captures new request.

Example

GET /login HTTP/2

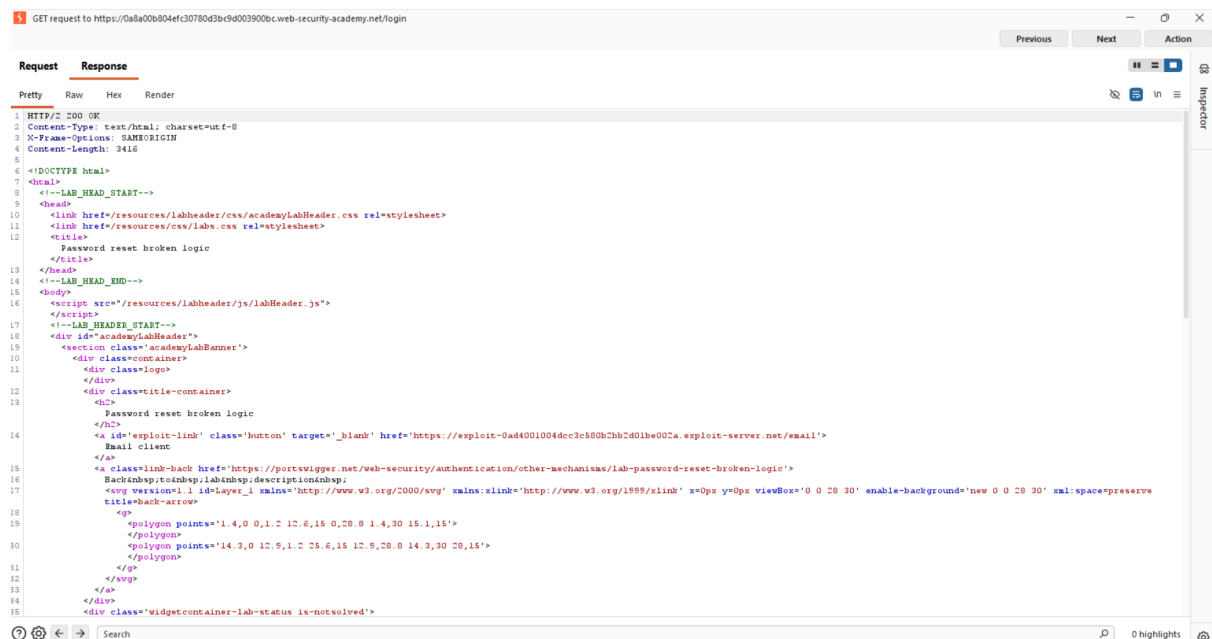
Screenshot 5

Login Page Request



Screenshot 6

Login Page Response



Analysis

Method

GET

Purpose

Request login page.

Response

200 OK

Data Returned

- HTML Form
- Username field
- Password field

PART D – LOGIN REQUEST ANALYSIS

Step 6: Enter Credentials

Example:Username: testuser@gmail.com

Password: Password123

Click Login.

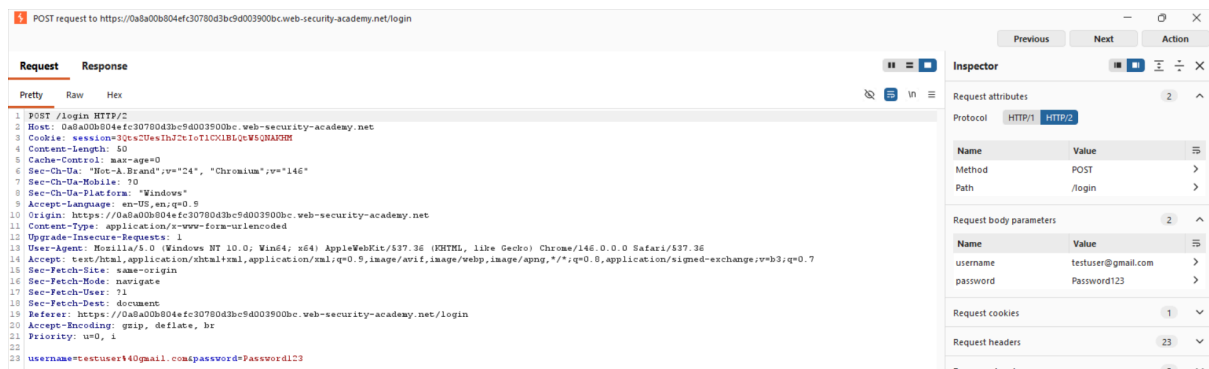
Request Captured

- POST /login HTTP/2
- username= testuser@gmail.com
- password=Password123

Screenshot 7

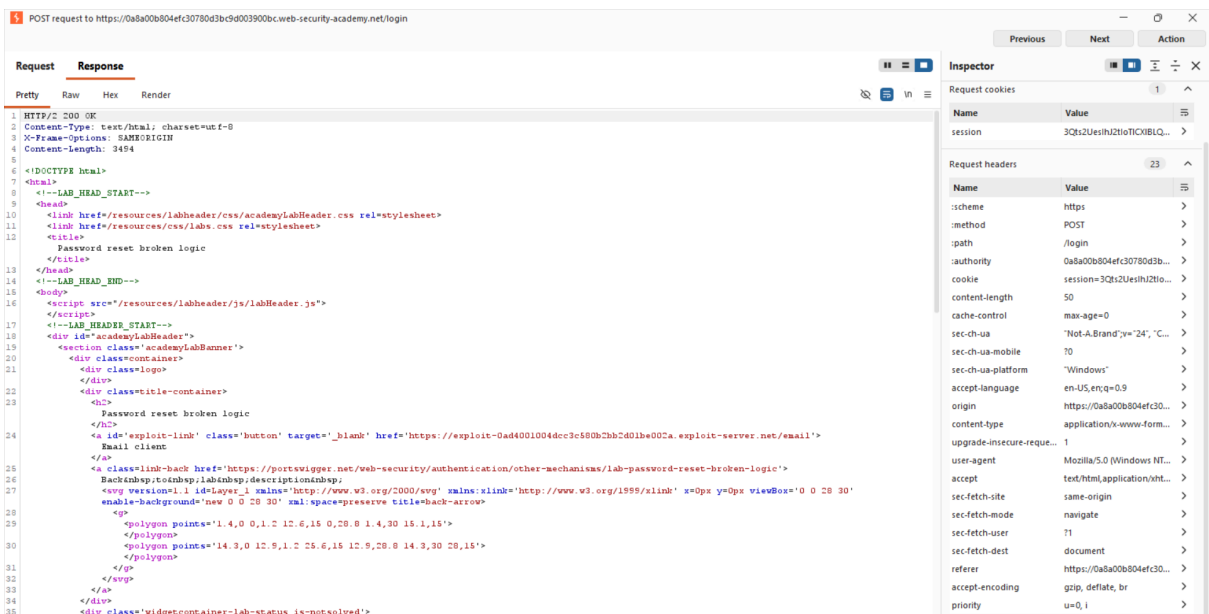
Login Request Highlight:

- POST
- Username
- Password



Screenshot 8

Login Response



Detailed Analysis

Method

POST

Why POST?

Sensitive information is sent securely in the request body.

Parameters Found

Parameter	Purpose
username	User identification
password	Authentication

Response Code

Usually:

200 OK

Meaning

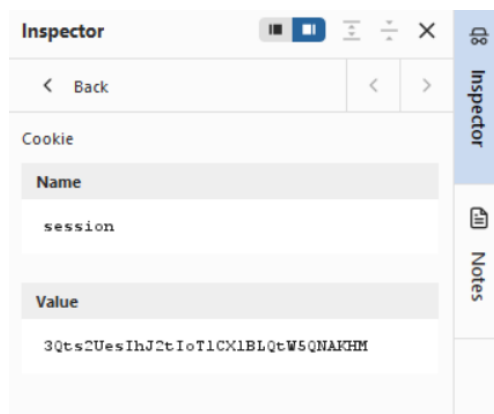
User successfully authenticated.

PART E – SESSION COOKIE ANALYSIS

Step 7: Locate Set-Cookie Header

Look at Login Response.

Screenshot :Session Cookie=30ts2UesIhJZtIoT1CX1BLQtW5QNAKHM



Analysis

What Happened?

The server created a session.

Purpose

Uniquely identifies logged-in users.

Importance

Without session cookie:

- User becomes anonymous
- Protected pages inaccessible

PART F – BEFORE LOGIN VS AFTER LOGIN

Before Login

Request:

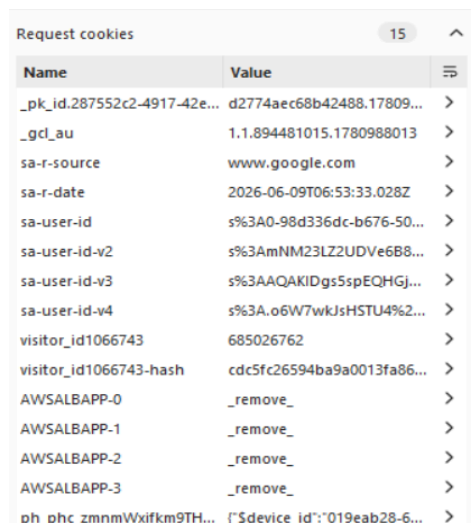
GET /

Cookie:

visitor=1066743

Screenshot :

Before Login Cookies



Name	Value	
_pk_id.287552c2-4917-42e...	d2774aec68b42488.17809...	>
_gcl_au	1.1.894481015.1780988013	>
sa-r-source	www.google.com	>
sa-r-date	2026-06-09T06:53:33.028Z	>
sa-user-id	s%3A0-98d336dc-b676-50...	>
sa-user-id-v2	s%3AmNM23LZ2UDVe6B8...	>
sa-user-id-v3	s%3AAQAKIDgs5spEQHGj...	>
sa-user-id-v4	s%3A.o6W7wkJsHSTU4%2...	>
visitor_id1066743	685026762	>
visitor_id1066743-hash	cdc5fc26594ba9a0013fa86...	>
AWSALBAPP-0	_remove_	>
AWSALBAPP-1	_remove_	>
AWSALBAPP-2	_remove_	>
AWSALBAPP-3	_remove_	>
ph_phc_zmnmWxifkm9TH...	["\$device_id": "019eab28-6...	>

After Login

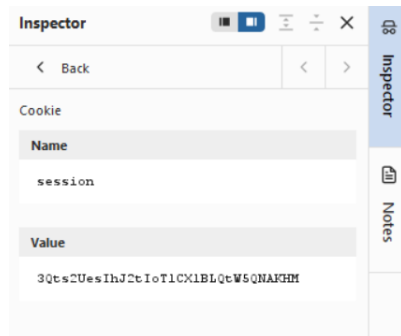
Request:

GET /my-account

Cookie: session=30ts2UesIhJZtIoT1CX1BLQtW5QNAKHM

Screenshot :

After Login Cookies



Comparison Table

Feature	Before Login	After Login
Authentication Status	Not Authenticated	Authenticated
Session Cookie	Not Present	session
Session ID	None	30ts2UesIhJZtIoT1CX1BLQtW5QNAKHM
User Access	Public Pages	Account Pages
User Identity	Unknown	Verified
Server Session	Not Created	Created

Questions and Answers

Q.What changes after login?

ANS.After successful authentication:

1. Server validates username and password.
2. A new session is created.
3. Session cookie (session) is assigned to the browser.
4. User becomes authenticated.
5. Protected resources become accessible.
6. Every subsequent request contains the session cookie.

Q.Which cookie maintains the session?

ANS. session=30ts2UesIhJZtIoT1CX1BLQtW5QNAKHM.This cookie maintains the user's session.

Q.Does session cookie change after login?

ANS.Yes.

Before login, there was no authenticated session cookie visible.

After successful login, the application generated a new session cookie:

session=30ts2UesIhJZtIoT1CX1BLQtW5QNAKHM

This new session ID is used to maintain the authenticated session. Many web applications intentionally generate a fresh session ID after login to prevent **Session Fixation attacks** and improve security.

PART G – LOGOUT ANALYSIS

Step 8: Logout

Click:

Logout

Sign Out

Request

Example:

GET/users /logout

Logout Request

[illegible]

Screenshot :

Logout Response

GET request to https://portswigger.net/users/logout

Request **Response**

Pretty Raw Hex Render

```

1 HTTP/2 302 Found
2 Content-Length: 0
3 Location: https://login.portswigger.net/?logout?client_id=F1PNC6GosguuM05EQd8erTCxvP9W6Gesturntohtcp3A327P2Portswigger.net1ZF
4 Date: Thu, 11 Jun 2026 07:54:41 GMT
5 Server: Kestrel
6 Cache-Control: no-cache, no-store
7 Expires: Thu, 01 Jan 1970 00:00:00 GMT
8 Pragma: no-cache
9 Set-Cookie: SessionId=
10 CDF0F1M6VQ04Ipsf0r123DhfytslmbhNCHB9K0mPiceFASh8eQ74d4TTP4D24wg9F7Dyle0MHcubys0hrs9Gcb9FpuH0KrfDe3i3ALQ7c7D7FahSDUgytCtcl4d8p471Yfr3u178u1fgcvr2CB2Gm
11 dyfalh3tq8Fohbt; max-age=43200; domain=.portswigger.net; path=/; secure; samesite=las; httponly
12 Set-Cookie: AspNetCore.Cookies=; expires=Thu, 01 Jan 1970 00:00:00 GMT; path=/; secure; samesite=las; httponly
13 Set-Cookie: AspNetCore.Cookies=; expires=Thu, 01 Jan 1970 00:00:00 GMT; path=/; secure; samesite=las; httponly
14 Set-Cookie: AspNetCore.Cookies=; expires=Thu, 01 Jan 1970 00:00:00 GMT; path=/; secure; samesite=las; httponly
15 Set-Cookie: AWALBAPP-0=remove_; Expires=Thu, 10 Jun 2026 07:54:41 GMT; Path=/
16 Set-Cookie: AWALBAPP-1=remove_; Expires=Thu, 10 Jun 2026 07:54:41 GMT; Path=/
17 Set-Cookie: AWALBAPP-2=remove_; Expires=Thu, 10 Jun 2026 07:54:41 GMT; Path=/
18 Set-Cookie: AWALBAPP-3=remove_; Expires=Thu, 10 Jun 2026 07:54:41 GMT; Path=/
19 Strict-Transport-Security: max-age=31536000; preload
20 X-Content-Type-Options: nosniff
21 X-Frame-Options: SAMEORIGIN
22 X-Xss-Protection: 1; mode=block
23 Content-Security-Policy: default-src 'none'; form-action 'self'; base-uri 'none'; connect-src 'self' https://ps.containers.pivx.pro https://ps.pivx.pro
24 https://tags.srv.stackadapt.com https://tracking-api.g2.com https://phingest.staging.portswigger.com
25 https://www.google.com/recaptcha/; font-src 'self'; frame-src https://www.google.com/recaptcha/img-src 'self' https://i.ytimg.com/
26 https://tags.srv.stackadapt.com/sa.jpegmedia-src 'self'; script-src 'self' https://ps.containers.pivx.pro/ppan.js https://ps.pivx.pro/ppan.js
27 https://www.youtube.com/iframe-api https://www.youtube.com https://tags.srv.stackadapt.com/avents.js https://go.portswigger.net/pd.js
28 https://phingest.staging.portswigger.com 'nonce=3obhKckGfGto70k7dbFrGvUqayUwId' 'strict-dynamic'; style-src 'self' https://tags.srv.stackadapt.com/sa.css;
29 Cross-Origin-Resource-Policy: same-origin
30 Cross-Origin-Opener-Policy: same-origin
31 X-Cache: Miss from cloudfront
32 Via: 1.1 59be060be0e4c981ae3367370c4af84.cloudfront.net (CloudFront)
33 X-Amz-CF-Pop: FRA56-P14
34 X-Amz-CF-Id: NpUp-foh1Tj2Ps0N0u0cF0MZT7c3VZM8aBuHr16KScy7R6XV7HFW==

```

Inspector

Request attributes 2

Protocol HTTP/2 HTTP/2

Name	Value
Method	GET
Path	/users/logout

Request cookies 25

Request headers 43

Response headers 26

Analysis

What Happens?

Server:

1. Invalidates session.
2. Deletes session record.
3. Redirects user to homepage.

Example Response

Set-Cookie:

session=deleted

Q.What happens after logout?

ANS:User:

- Loses authenticated status
- Must login again
- Cannot access protected pages

PART H – REPEATER ANALYSIS

Step 9: Send Login Request to Repeater

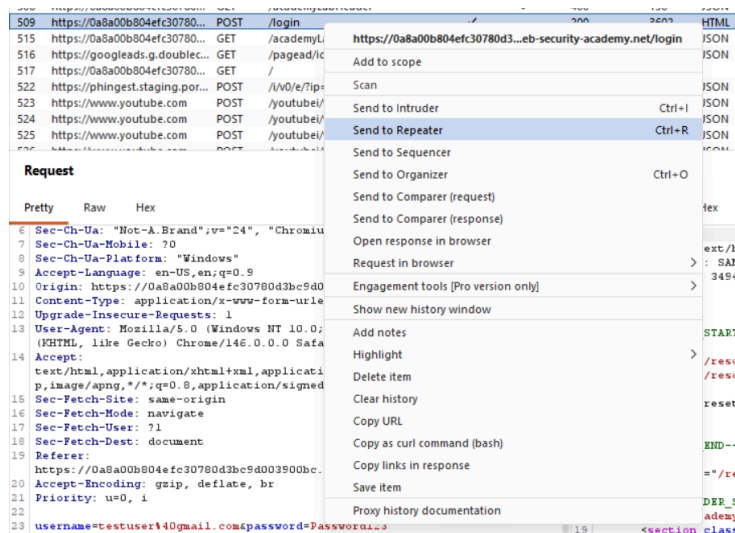
Right click Login Request.

Select:

Send to Repeater

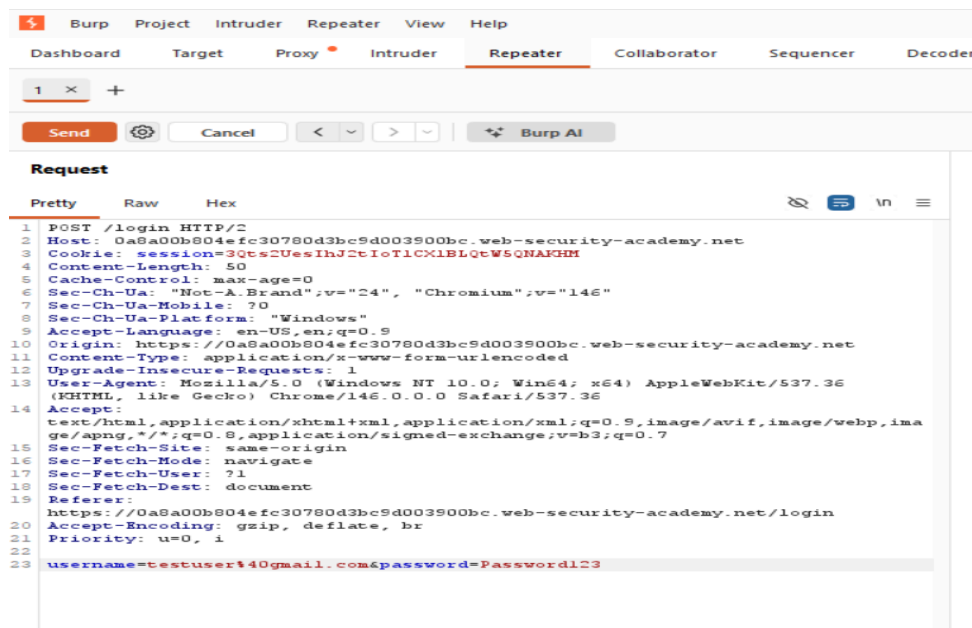
Screenshot :

Send To Repeater



Step 10: Analyze Request

Screenshot :Repeater Request



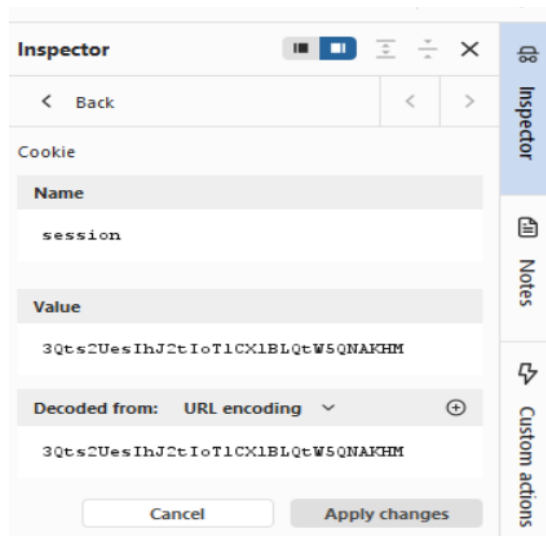
Headers Analysis

SCREENSHOT:

Request headers		23	^
Name	Value		
:scheme	https	>	
:method	POST	>	
:path	/login	>	
:authority	0a8a00b804efc30780...	>	
cookie	session=3Qts2UesIhJ...	>	
content-length	50	>	
cache-control	max-age=0	>	
sec-ch-ua	"Not-A.Brand";v="24",...	>	
sec-ch-ua-mobile	?0	>	
sec-ch-ua-platform	"Windows"	>	
accept-language	en-US,en;q=0.9	>	
origin	https://0a8a00b804ef...	>	
content-type	application/x-www-f...	>	
upgrade-insecure-re...	1	>	
user-agent	Mozilla/5.0 (Windows...	>	
accept	text/html,application/...	>	
sec-fetch-site	same-origin	>	
sec-fetch-mode	navigate	>	
sec-fetch-user	?1	>	
sec-fetch-dest	document	>	
referer	https://0a8a00b804ef...	>	
accept-encoding	gzip, deflate, br	>	

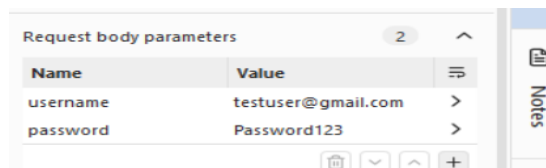
Cookie Analysis

Screenshot:



Parameter Analysis

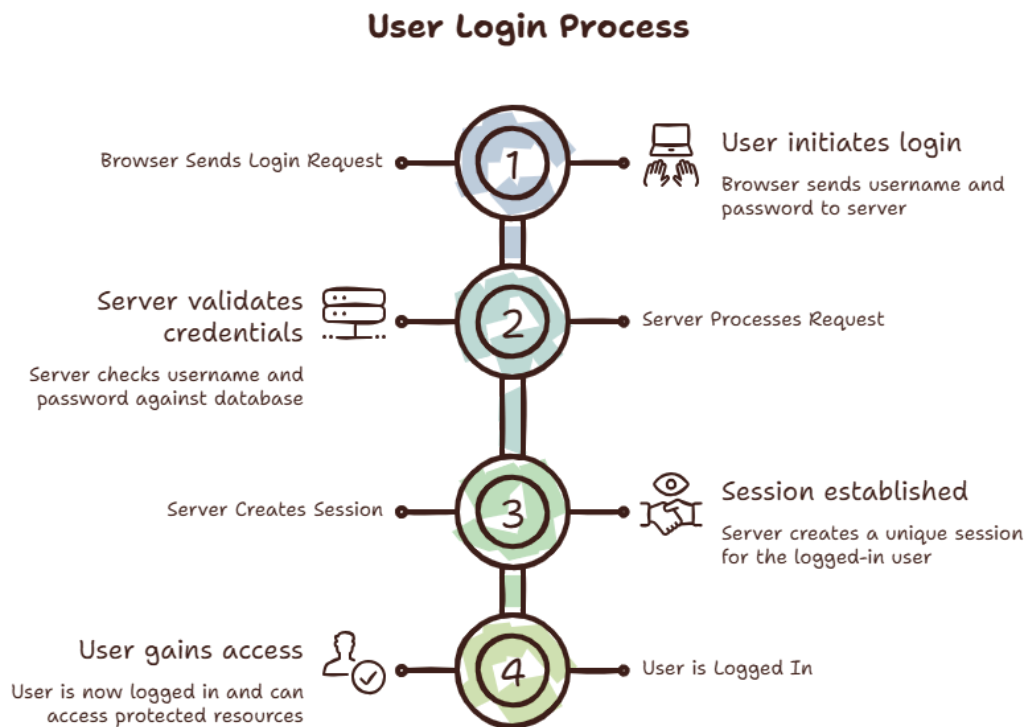
Screenshot:



Response Analysis



LOGIN FLOW DIAGRAM



Theory Questions

1. What is Authentication?

Definition

Authentication is the process of verifying the identity of a user, system, or device before granting access to an application or service.

In simple words, authentication answers the question:

"Who are you?"

The system checks whether the user is really the person they claim to be.

How Authentication Works

When a user enters credentials, the server compares them with the stored records.

Process:

1. User enters username/email.
2. User enters password.
3. The credentials are sent to the server.
4. The server verifies the information.
5. If valid, access is granted.
6. If invalid, access is denied.

2. What is Authorization?

Definition

Authorization is the process of determining what resources and actions an authenticated user is allowed to access.

It answers the question:

"What are you allowed to do?"

How Authorization Works

After successful authentication:

1. The system identifies the user's role.
2. Permissions associated with that role are checked.
3. Appropriate access is granted.

3. What is a Session?

Definition

A session is a temporary interaction between a user and a web application that allows the server to remember the user's identity and activities across multiple requests.

Why Sessions Are Needed

HTTP is a **stateless protocol**.

This means:

The server forgets previous requests once they are completed.

Without sessions:

- Users would need to log in on every page.

Sessions solve this problem.

4. What is a Cookie?

Definition

A cookie is a small text file stored by the browser that contains information sent by the web server.

Cookies help websites remember users and maintain sessions.

Information Stored in Cookies

Cookies may contain:

- Session IDs
- User preferences
- Language settings
- Shopping cart information
- Login tokens

5. Difference Between Authentication and Authorization

Authentication	Authorization
Verifies user identity	Determines permissions
Answers "Who are you?"	Answers "What can you do?"
Occurs first	Occurs after authentication
Uses credentials	Uses roles and policies
Login process	Access control process
Example: Gmail login	Accessing Gmail settings

6. Difference Between Session Cookies and Persistent Cookies

Session Cookies	Persistent Cookies
Temporary	Long-term
Deleted after browser closes	Remain until expiry
No expiration date	Have expiration dates
Used to maintain active sessions	Used to remember users
Stored in memory	Stored on disk
More secure	Convenient but may increase risk

LOGIN FLOW ANALYSIS OF POPULAR WEBSITES

Gmail

Login Flow

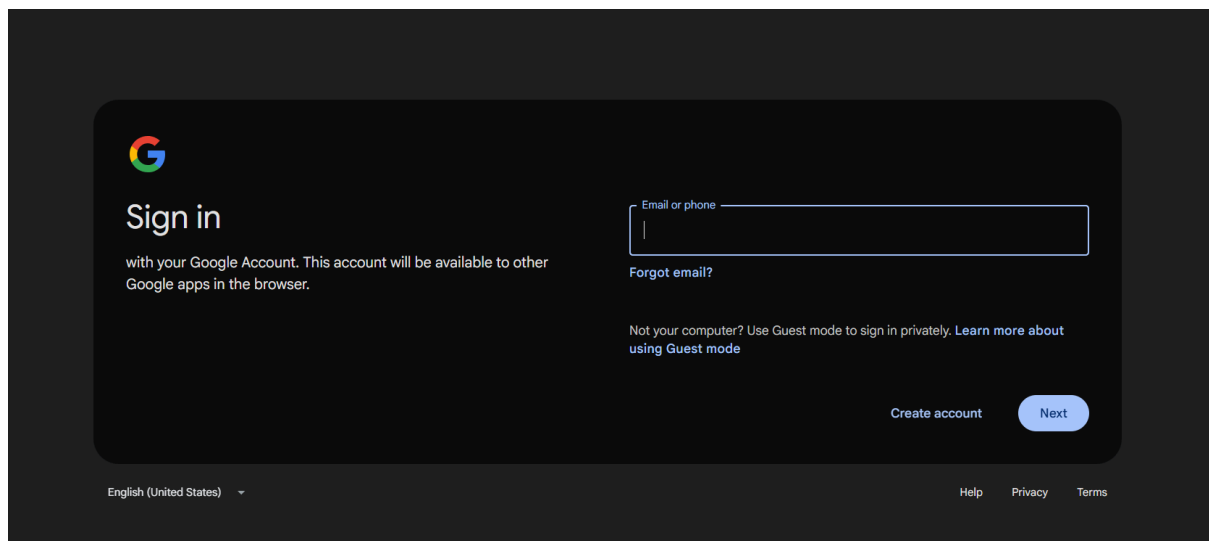
1. Enter Email
2. Click Next
3. Enter Password
4. MFA Verification
5. Access Mailbox

Security Features

- Two-Factor Authentication
- Device Recognition
- Suspicious Login Detection

Screenshot :

Gmail Login Page



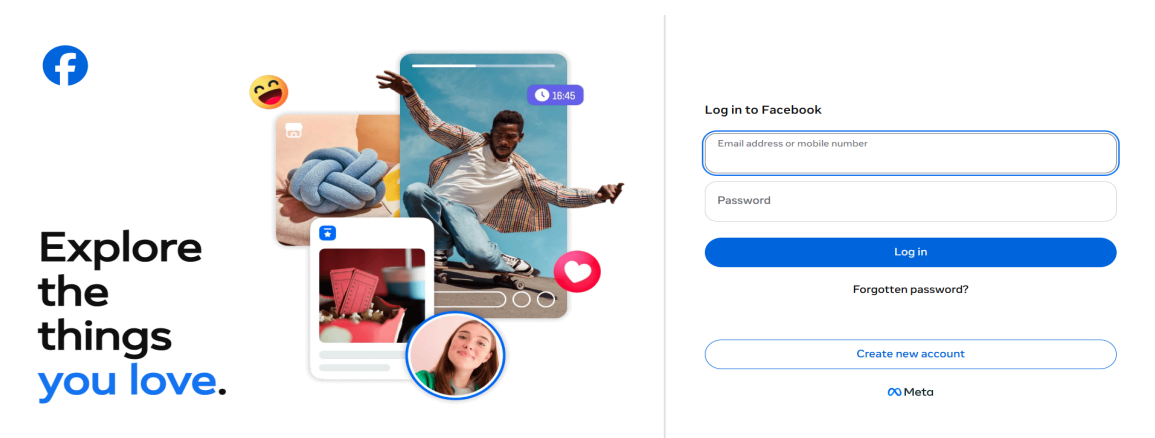
Facebook

Security Features

- OTP Verification
- Login Alerts
- Device Verification
- 2FA

Screenshot :

Facebook Login Page



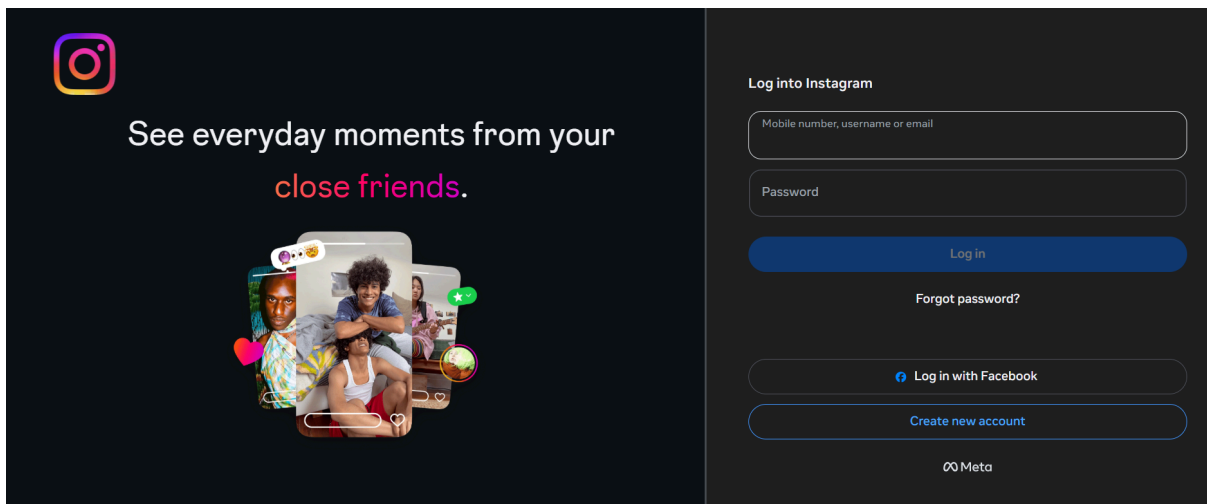
Instagram

Security Features

- OTP Verification
- Login Activity Monitoring
- Two-Factor Authentication

Screenshot :

Instagram Login Page



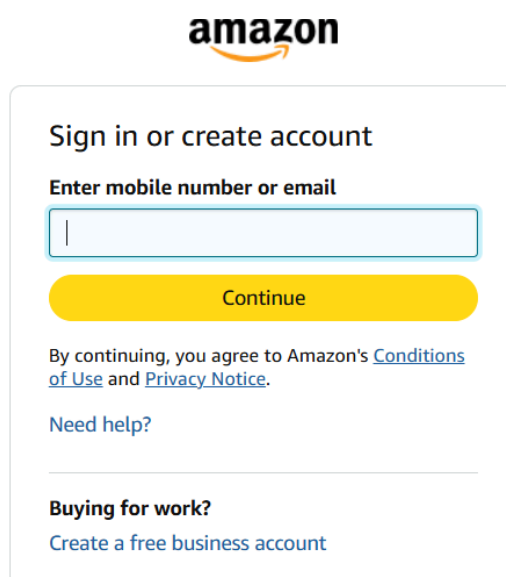
Amazon

Security Features

- Multi-Factor Authentication
- OTP Verification
- Fraud Detection System
- Device Recognition

Screenshot:

Amazon Login Page



Conclusion

The experiment successfully demonstrated the working of authentication, authorization, sessions, and cookies using Burp Suite. Login and logout requests were captured and analyzed. Session cookies responsible for maintaining user authentication were identified. Burp Repeater was used to inspect requests and responses, and the login flows of major web applications were studied to understand modern web security mechanisms.